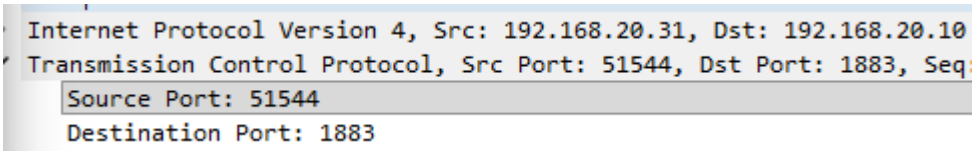
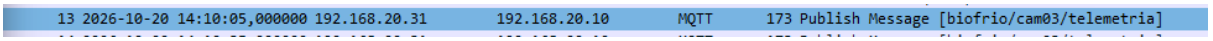
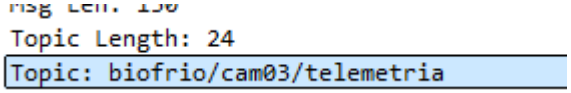
Questão 1:
IP do dispositivo(cliente): 192.168.20.31
IP do servidor 192.168.20.10.
Porta de Destino: 1883.



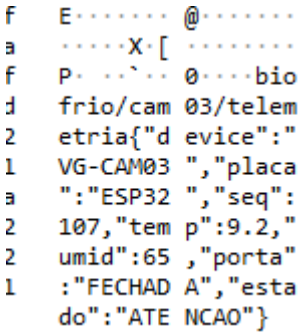
Protocolo de aplicação: MQTT



Tópico MQTT da telemetria: biofrio/cam03/telemetria

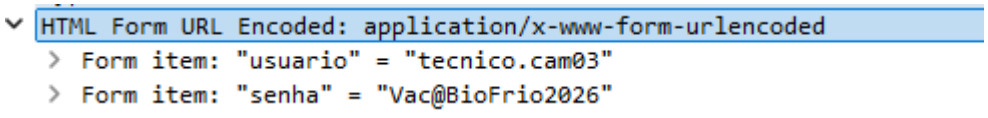


Modelo da placa informado no JSON: ESP32

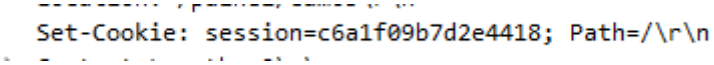


Questão 2:

- Qual o usuário enviado no formulário de login do painel: técnico.cam03
- Qual a senha enviada: “Vac@BioFrio2026”;
- O que significa %40 = O código %40 representa o caractere especial arroba (@) codificado no padrão URL Encoding (percent-encoding), onde o caractere @ é substituído pelo seu valor hexadecimal na tabela ASCII.

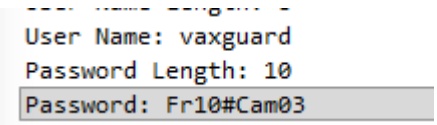


- Qual identificador de sessão (cookie) o servidor devolveu após o login?



c6a1f09b7d2e4418;

- O broker MQTT também recebeu usuário e senha em texto claro. Informe o usuário e a senha usados pelo dispositivo para se conectar ao broker: Client ID: vaxguard-cam03; Password: Fr10#Cam03



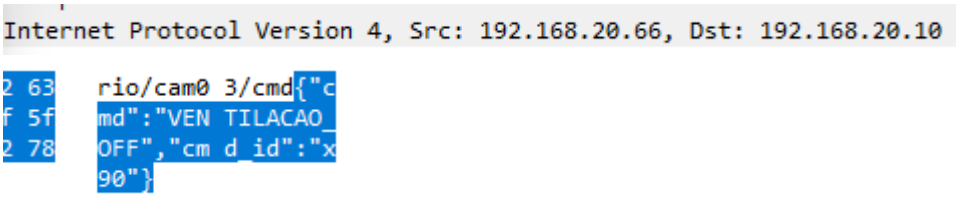
- Que falha de segurança essas observações evidenciam? Que correções você recomendaria?
  O sistema opera sem criptografia (utilizando HTTP em vez de HTTPS e MQTT em texto plano), permitindo que credenciais de login, cookies de sessão e comandos críticos sejam interceptados facilmente por ataques de escuta de rede (*sniffing*).

Recomendações de correção:

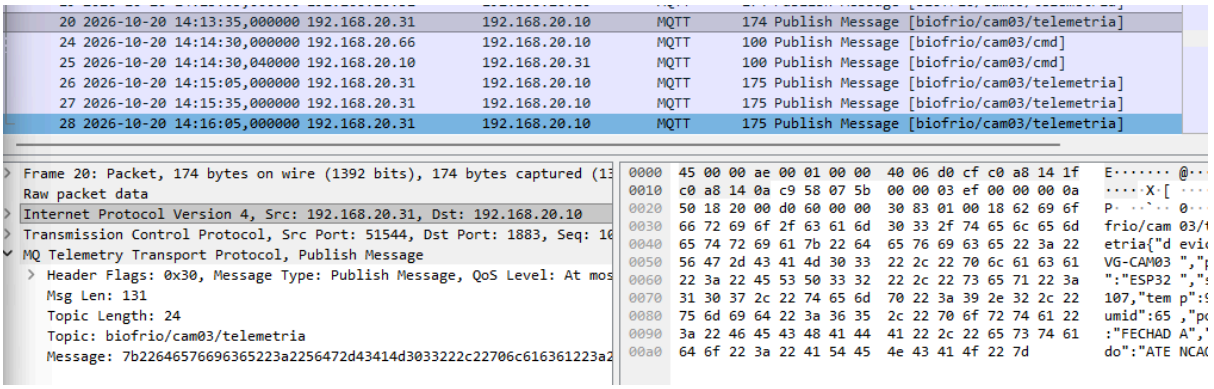
1. Implementar **TLS/SSL** em toda a aplicação web (forçando o uso de **HTTPS**) para criptografar o tráfego HTTP e proteger os cookies de sessão e credenciais.
2. Configurar o broker MQTT para utilizar conexões seguras com criptografia (**MQTTS** / TLS nas portas corretas, como a 8883) em vez de conexões não criptografadas.

Questão 3:

a) 192.168.20.66, Ventilação OFF

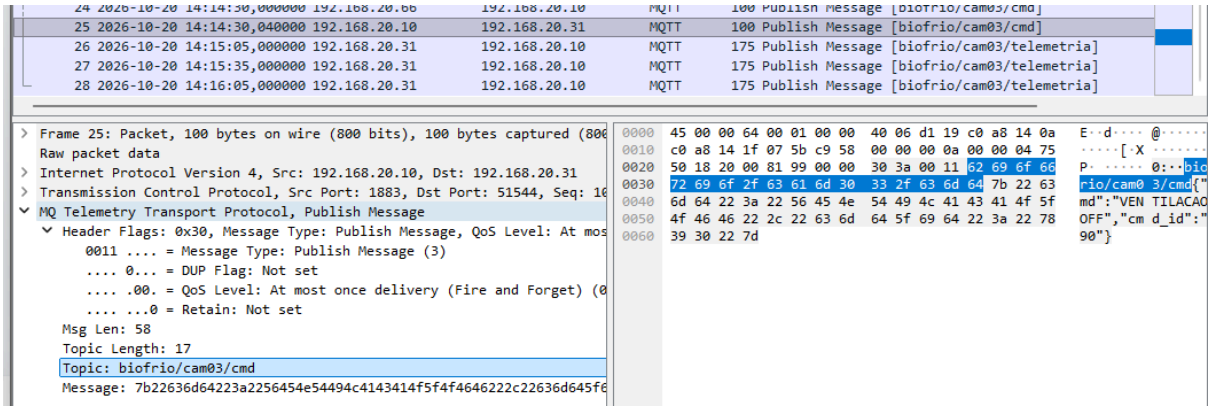


b) Não, o IP comum de origem de onde vem as respostas legítimas do sistema é 192.168.20.10

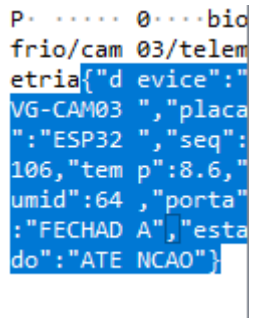


c) **Inscrição do dispositivo:** O dispositivo vaxguard-cam03 (192.168.20.31) realizou a inscrição (*SUBSCRIBE*) no tópico **biofrio/cam03/cmd** logo após se conectar ao broker MQTT.

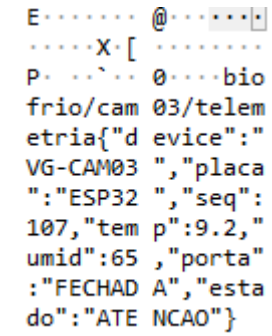
Por que o broker repassou o comando? O broker MQTT atua apenas como um intermediário de mensagens baseado no modelo *Publish/Subscribe*. Como o host não autorizado publicou a mensagem no tópico biofrio/cam03/cmd e o dispositivo estava inscrito nesse mesmo tópico, o broker simplesmente entregou o pacote a todos os inscritos ativos. Como não havia regras de autorização/Listas de Controle de Acesso (ACL) no broker limitando quem poderia publicar no tópico de comandos, a mensagem foi entregue normalmente.



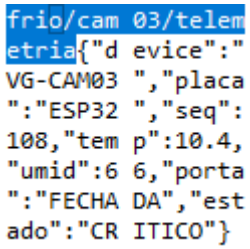
d)
Antes das 14:14:30 (Antes do comando):
14.13.05 =



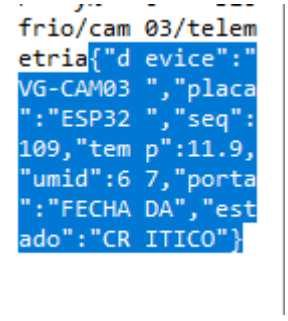
14:13:35 =



DEPOIS:
14:15:05 =



Após as 14:14:30 (Envio do comando `VENTILACAO_OFF`):



Efeito provável: O comando `VENTILACAO_OFF` desligou a circulação forçada de ar frio na câmara. Sem a ventilação para trocar calor, a temperatura interna disparou rapidamente, consolidando a excursão térmica.

e) Mecanismos de segurança:
Para impedir que qualquer host não autorizado publicasse comandos aceitos pelo dispositivo, os seguintes mecanismos deveriam estar implementados:

1. **Listas de Controle de Acesso (ACLs) no Broker MQTT:** Configurar o broker MQTT para restringir as permissões de publicação por tópico, garantindo que apenas a aplicação central (192.168.20.10) tenha permissão de escrita/publicação no tópico biofrio/cam03/cmd, enquanto os dispositivos finais apenas leiam.
2. **Autenticação por Certificados Digitais Mututais (mTLS):** Exigir autenticação mTLS baseada em certificados de chave pública (X.509) para conexões MQTT, permitindo que apenas dispositivos e servidores previamente autorizados com certificados válidos consigam conectar e interagir no broker.
3. **Assinatura / Criptografia no Payload de Comando:** O dispositivo só aceitaria comandos que contivessem uma assinatura criptográfica ou MAC (Message Authentication Code) gerada pelo servidor central, rejeitando mensagens vindas de terceiros sem a chave privada de assinatura.

Questão 4:

a) Monte uma linha do tempo do incidente (horário → evento), do primeiro login à última leitura CRÍTICA:

Autenticação Web: O operador tecnico.cam03 realiza login via HTTP POST no painel (192.168.20.10) utilizando a senha Vac@BioFrio2026, recebendo o cookie de sessão session=c6a1f09b7d2e4418.
Conexão e Inscrição MQTT: O dispositivo ESP32 (192.168.20.31) conecta-se ao broker MQTT (192.168.20.10) com o utilizador vaxguard e senha Fr10#Cam03, inscrevendo-se nos tópicos de controlo.
Fase Normal (Seq 100 a 105): A telemetria reporta temperaturas estáveis entre **4.8°C** e **7.8°C**, com estado NORMAL.
Fase de Atenção (Seq 106 e 107): A temperatura sobe para **8.6°C** e **9.2°C**, alterando o estado da câmara para ATENCAO.
Injeção do Comando Malicioso (Por volta das 14:14:30): O host não autorizado 192.168.20.66 publica diretamente no broker o comando {"cmd":"VENTILACAO_OFF","cmd_id":"x90"} no tópico biofrio/cam03/cmd.
Fase Crítica (Seq 108 a 110): Desprovida de ventilação, a temperatura dispara rapidamente para **10.4°C**, **11.9°C** e atinge o pico de **13.5°C**, registando estado CRITICO
PROVAS: Com base nos prints anteriores é possível fazer essa inferência.

b) Classifique o incidente:
Classificação: Ação maliciosa (injeção não autorizada de comandos via MQTT).
Fundamentação: O incidente não decorreu de uma falha mecânica natural do equipamento nem de um erro operacional legítimo. A análise dos pacotes comprova que o comando de desativação (VENTILACAO_OFF) foi injetado por um endereço IP estranho à arquitetura de controlo legítima — o host 192.168.20.66 — aproveitando-se da ausência de restrições de publicação no broker MQTT para forçar a excursão térmica.

PROVAS: Com base nos prints anteriores é possível fazer essa inferência.

c) Proponha três medidas técnicas que a BioFrio deveria adotar para que esse mesmo tráfego, se capturado de novo, não revelasse credenciais nem permitisse comandos não autorizados (pense em criptografia de transporte, autenticação de mensagens e controle de acesso ao broker):

Criptografia de Transporte em Toda a Rede (HTTPS e MQTTS): Implementar certificados TLS/SSL nas aplicações web (HTTPS) e no broker MQTT (MQTTS na porta 8883),

eliminando o tráfego em texto claro que expôs credenciais de painel, cookies de sessão e passwords de dispositivos como Fr10#Cam03.

Controle de Acesso Rigoroso (ACLs no Broker MQTT): Configurar Listas de Controle de Acesso no broker para restringir estritamente as permissões de escrita/publicação no tópico de comandos (biofrio/cam03/cmd), permitindo que apenas o servidor central legítimo envie comandos e bloqueando imediatamente tentativas de hosts espúrios como o 192.168.20.66.

Autenticação Mútua por Certificados (mTLS): Substituir ou complementar a autenticação básica baseada em passwords estáticas por mTLS (Mutual Transport Layer Security), garantindo que apenas dispositivos rigorosamente provisionados e com certificados válidos consigam estabelecer comunicação na rede industrial.